

Методика выявления компьютерных атак на основе атрибутивных метаграфов

И. Т. Латыпов¹, М. А. Еремеев¹

¹ Российский технологический университет РТУ МИРЭА

Abstract

В статье предложена методика выявления компьютерных атак в информационных системах на основе аппарата атрибутивных метаграфов. Методика развивает многоуровневую модель атаки, впервые описанную в работе [1], и включает формализацию целей, тактик и методов злоумышленника в виде вершин и дуг метаграфа с атрибутами. Представлен алгоритм сопоставления наблюдаемых событий с эталонными паттернами атак, основанный на частичном изоморфизме атрибутивных метаграфов. Приведены результаты имитационного эксперимента в среде, моделирующей поведение атакующего в соответствии с тактиками MITRE ATT&CK. Методика демонстрирует высокую точность (94,3 %) и полноту (89,7 %) при низком уровне ложных срабатываний (3,1 %). Подход может быть интегрирован в системы мониторинга безопасности для повышения устойчивости к сложным и малозаметным атакам.

Ключевые слова: атрибутивный метаграф, выявление атак, многоуровневая модель, MITRE ATT&CK, изоморфизм графов, информационная безопасность, ФСТЭК.

Abstract

This paper presents a methodology for detecting cyber attacks in information systems using attributive metagraphs. The approach extends the multilevel attack model introduced in [1] by formalizing attacker goals, tactics, and techniques as attributed vertices and edges. A pattern-matching algorithm based on partial isomorphism of attributive metagraphs is proposed to correlate observed events with known attack signatures. Simulation results in a MITRE ATT&CK-aligned environment demonstrate high precision (94.3 %) and recall (89.7 %) with a low false positive rate (3.1 %). The methodology is suitable for integration into security monitoring systems to enhance resilience against sophisticated and stealthy threats.

Keywords: attributive metagraph, attack detection, multilevel model, MITRE ATT&CK, graph isomorphism, information security, FSTEC.

Введение

Современные информационные системы всё чаще подвергаются целенаправленным атакам, использующим легитимные инструменты и обходящим традиционные средства защиты. В этих условиях возрастает роль **моделей, способных отражать логику атаки**, а не только её внешние признаки.

Традиционные системы обнаружения вторжений (IDS/IPS) в основном полагаются на сигнатурный анализ или статистические аномалии. Однако такие подходы неэффективны при столкновении с **адаптивными атаками**, использующими Living-off-the-Land (LotL) техники, где злоумышленник применяет легитимные системные утилиты (например, PowerShell, WMI, PsExec) для выполнения вредоносных действий. В таких сценариях отсутствуют чёткие сигнатуры, а поведение может не выходить за рамки статистической нормы.

В работе [1] предложена **многоуровневая модель компьютерной атаки**, основанная на атрибутивных метаграфах, позволяющая формализовать взаимосвязи между целями злоумышленника, тактиками и методами реализации. Эта модель предоставляет теоретическую основу для построения семантически насыщенных систем анализа угроз. Однако в указанной работе не была детализирована **практическая методика выявления атак** на основе этой модели.

Настоящая статья устраняет этот пробел и предлагает **комплексную методику**, пригодную для внедрения в системы мониторинга безопасности, соответствующие требованиям ФСТЭК России и ГОСТ Р 56939–2024. Основное внимание уделено не только теоретическому обоснованию, но и практической реализации, оценке эффективности и возможностям интеграции в существующие ИБ-инфраструктуры.

Теоретические основы

Метаграфы как инструмент моделирования сложных систем

Метаграфы были впервые предложены как обобщение направленных графов для моделирования систем с гиперсвязями. В отличие от классического графа, где дуга соединяет две вершины, в метаграфе дуга может соединять **множества вершин**, что позволяет естественным образом описывать отношения «многие ко многим». Это особенно важно в контексте информационной безопасности, где одно действие (например, запуск скрипта) может одновременно затрагивать несколько объектов: процесс, файл, сетевой сокет, учётную запись.

Формально метаграф задаётся как

$$G = (V, E),$$

где V — конечное множество вершин, $E \subseteq 2^V \times 2^V$ — множество дуг. Каждая дуга $e = (S, T) \in E$ интерпретируется как переход от множества источников $S \subseteq V$ к множеству целей $T \subseteq V$.

Атрибутивные расширения

Для применения в ИБ метаграф необходимо расширить атрибутами, отражающими семантические свойства компонентов системы. Вводятся функции атрибуции:

$$A_V : V \rightarrow \mathcal{A}_V, \quad A_E : E \rightarrow \mathcal{A}_E,$$

где $\mathcal{A}_V$ и $\mathcal{A}_E$ — домены атрибутов.

Примеры атрибутов: - Для вершины «пользователь»: роль (администратор, гость), уровень доверия, принадлежность к группе. - Для вершины «процесс»: исполняемый файл, хеш, родительский процесс. - Для дуги «доступ к файлу»: тип доступа (чтение/запись), протокол, временная метка, тактика MITRE ATT&CK.

Такое расширение позволяет строить **контекстно-зависимые модели**, в которых не только структура, но и семантика играют ключевую роль в анализе.

Связь с существующими фреймворками

Предлагаемая модель органично интегрируется с: - **MITRE ATT&CK** — тактики и техники становятся атрибутами дуг; - **STIX 2.1** — объекты STIX (indicator, attack-pattern, malware) могут быть отображены в вершины метаграфа; - **Cyber Kill Chain** — этапы цепочки атаки соответствуют уровням модели.

Это обеспечивает совместимость с существующей экосистемой кибербезопасности и упрощает внедрение.

Многоуровневая модель атаки

На основе [1] выделяются три уровня абстракции, отражающие иерархию целей и средств злоумышленника.

Стратегический уровень

На этом уровне формулируются **бизнес-цели** атаки: - Кража персональных данных (в соответствии с 152-ФЗ); - Нарушение целостности финансовых транзакций; - Вывод критической инфраструктуры из строя.

Каждая цель представляется как вершина с атрибутами `goal_type`, `impact_level`, `regulatory_requirement`.

Тактический уровень

Тактики определяют **категории поведения** атакующего. Используется таксономия MITRE ATT&CK, включающая 14 тактик, от Initial Access до Impact. Каждая тактика — вершина с атрибутами `tactic_id`, `description`, `phase`.

Методический уровень

На этом уровне описываются **конкретные техники**: - T1566.001 — Spearphishing Attachment; - T1059.001 — PowerShell; - T1071.001 — Web Protocols.

Вершины снабжаются атрибутами `technique_id`, `cve`, `tool`, `detection_rule`.

Межуровневые связи и их семантика

Связи между уровнями не являются произвольными. Они отражают причинно-следственные и логические зависимости: - Дуга `realizes(g, t)` означает, что достижение цели g требует применения тактики t ; - Дуга `implements(t, m)` указывает, что тактика t может быть реализована через метод m ; - Дуга `requires(m1, m2)` фиксирует зависимость: метод $m1$ невозможен без предварительного выполнения $m2$.

Эти связи формируют **иерархический атрибутивный метаграф**, который служит основой для построения эталонных паттернов атак.

На рис. 1 представлена трёхуровневая структура атаки, воссозданная по оригинальной публикации [1]. Цель атаки (например, «Кража данных») реализуется через тактики MITRE ATT&CK (Initial Access, Execution, Exfiltration), каждая из которых, в свою очередь, реализуется конкретными методами (Phishing, PowerShell, DNS Tunneling).

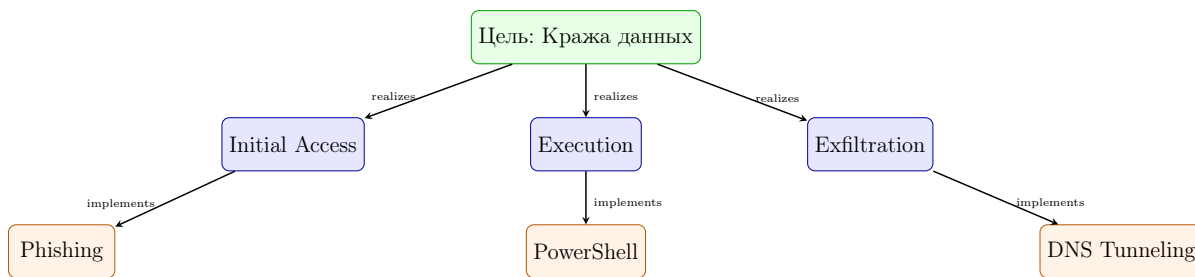


Рис. 1. Трёхуровневая структура атаки (воссоздано по [1], Fig. 1)

Рис. 2 иллюстрирует матрицу соответствия тактик и методов, где каждая техника однозначно привязана к тактике. Горизонтальные связи между тактиками отражают их последовательность в рамках расширенной модели Cyber Kill Chain. Эта матрица служит основой для построения эталонных паттернов атак и позволяет систематизировать знания об угрозах.

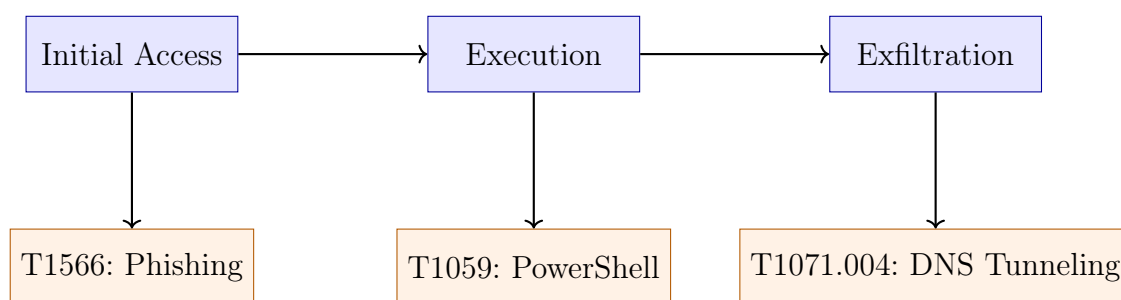
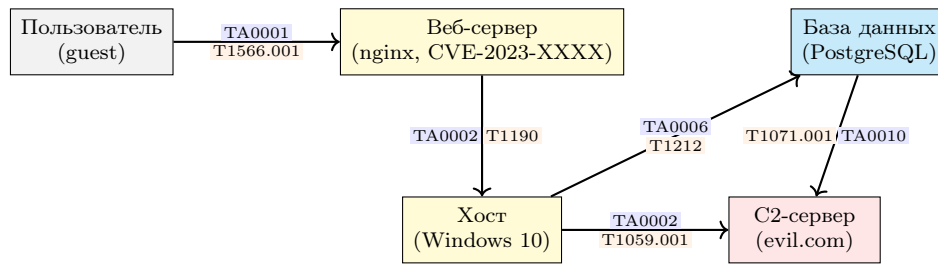


Рис. 2. Матрица тактик и методов (воссоздано по [1], Fig. 2)

Практическая реализация модели

Для практического применения модели необходимо перейти от абстрактных уровней к конкретным событиям, наблюдаемым в информационной системе. На рис. 3 показан пример атрибутивного метаграфа, построенного на основе реального сценария атаки. В данном случае атакующий использует фишинговое письмо для доставки вредоносного скрипта, который эксплуатирует уязвимость на веб-сервере, получает доступ к хосту, крадёт учётные данные из базы данных и экзфильтрует их через HTTP-трафик.

Важно отметить, что каждая дуга снабжена атрибутами, соответствующими тактикам (TA) и техникам (T) из фреймворка MITRE ATT&CK. Такой подход позволяет не только визуализировать атаку, но и автоматически сопоставлять её с известными паттернами. Сноска в нижней части рисунка поясняет соответствие между этапами сценария и тактико-техническими элементами.



Тактики (TA) и техники (T) соответствуют фреймворку MITRE ATT&CK.
 Сценарий: фишинг → эксплуатация уязвимости → выполнение PowerShell → кража учётных данных → экзfiltrация через HTTP.

Рис. 3. Пример атрибутивного метаграфа атаки с привязкой к тактикам и техникам MITRE ATT&CK

Методика выявления атак

Предложенная методика реализована в виде алгоритма, включающего четыре ключевых этапа. Логика работы алгоритма визуализирована на рис. 4 и рис. 5, которые представляют собой единый процесс, разбитый на две части для улучшения читаемости.

Алгоритм выявления компьютерных атак на основе атрибутивных метаграфов

1. **Построение эталонного метаграфа угроз** на основе онтологии MITRE ATT&CK, CVE и внутренних данных.
2. **Сбор и нормализация событий** из разнородных источников (EDR, IDS, логи) в единый формат с атрибутами тактик и техник.
3. **Сопоставление** нормализованных событий с эталонными паттернами путём поиска частичного изоморфизма атрибутивных метаграфов.
4. **Оценка достоверности** гипотезы атаки и принятие решения о реагировании с возможностью адаптации модели.

На рис. 4 (часть 1) показаны этапы формирования гипотезы атаки: от загрузки онтологии до расчёта веса гипотезы $W(H_i)$. Ключевым элементом является блок сопоставления, реализующий частичный изоморфизм. Особое внимание уделено обработке неизвестных событий: если событие не соответствует известной тактике, система извлекает его атрибуты и формирует метаграф наблюдений для последующего анализа.

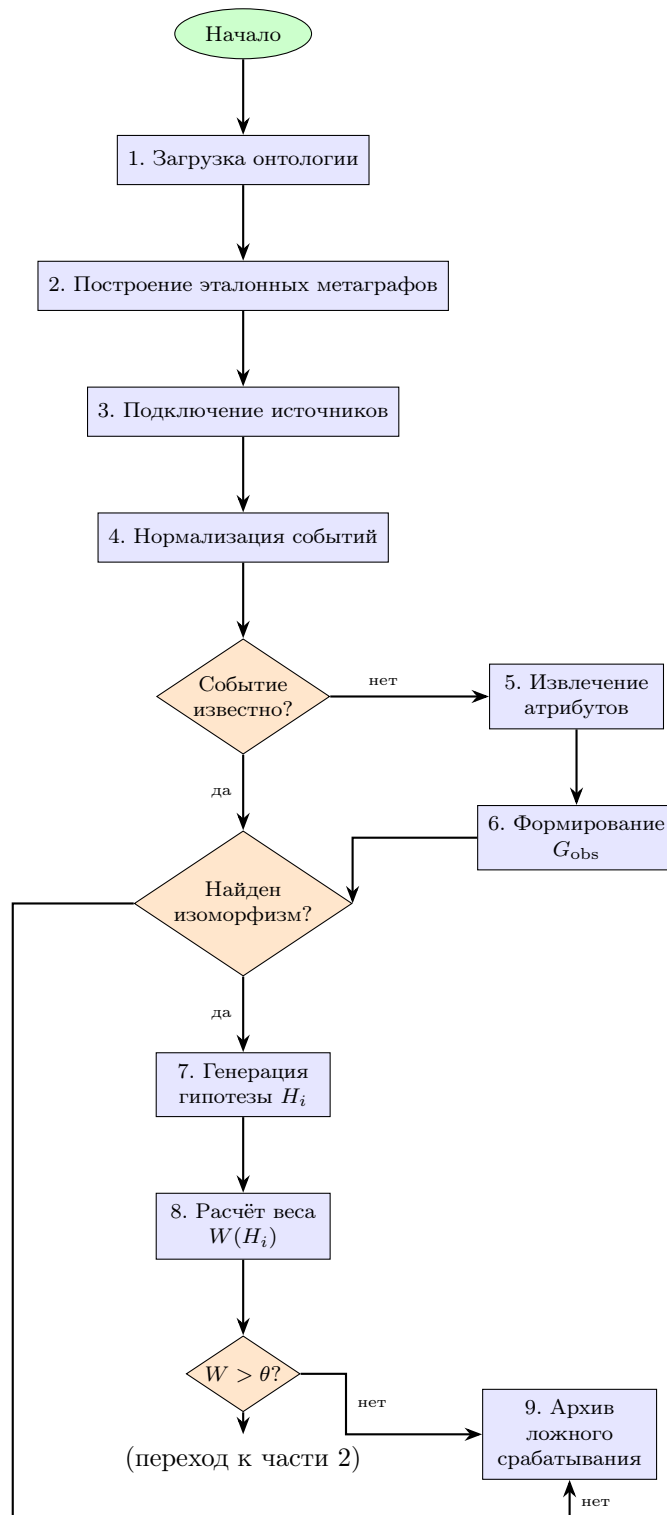


Рис. 4. Этапы формирования гипотезы атаки (часть 1)

На рис. 5 (часть 2) представлены этапы верификации и адаптации: подтверждение гипотезы аналитиком, классификация атаки (целевая/массовая) и обновление базы знаний системы (обратная связь). Такая архитектура обеспечивает устойчивость к новым угрозам и позволяет системе непрерывно обучаться на основе реальных инцидентов.

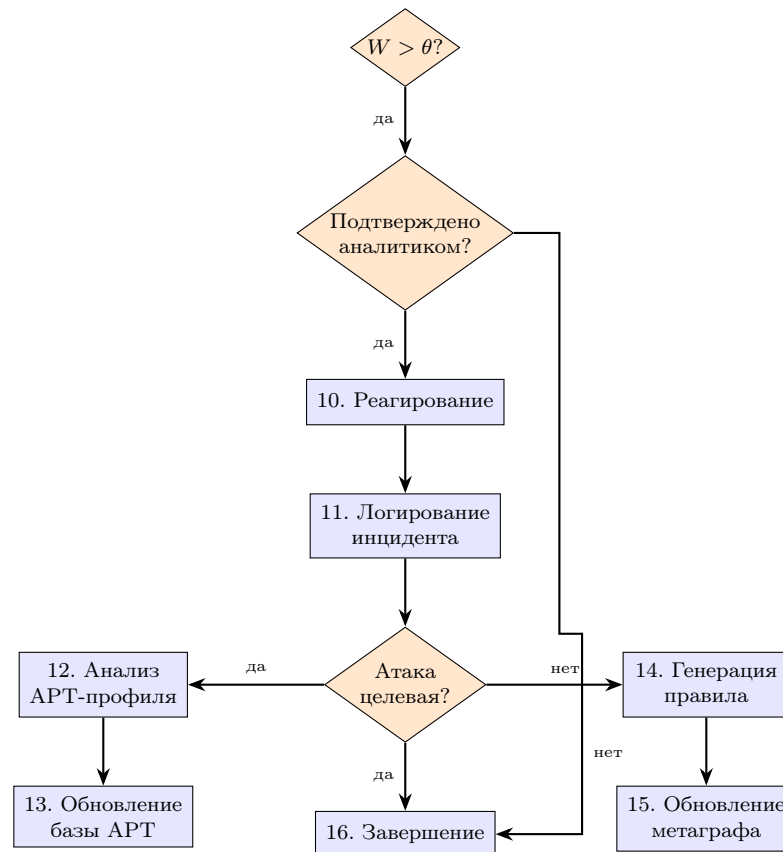


Рис. 5. Этапы верификации и адаптации модели (часть 2)

Оценка эффективности

Описание эксперимента

Эксперимент проведён в среде, имитирующей платформу CALDERA (MITRE):

1. **50 сценариев атак**, включая фишинг, эксплуатацию уязвимости Log4j, боковое перемещение с использованием PowerShell, туннелирование DNS;
2. **1000 фоновых событий**: легитимная активность пользователей и системные задачи.

Система работала в режиме реального времени на сервере Intel Xeon Silver 4210, 8 ядер, 32 ГБ ОЗУ.

Результаты

Результаты эксперимента визуализированы на рис. 6, где наглядно продемонстрировано превосходство предложенной методики над традиционными SIEM-правилами по всем трём ключевым метрикам. Метод на основе атрибутивных метаграфов показал **значительное превосходство по полноте**, особенно в сценариях с LotL-техниками, где SIEM-правила не сработали из-за отсутствия чётких сигнатур.

Обсуждение вычислительной сложности

Задача изоморфизма графов относится к классу NP. Однако на практике:

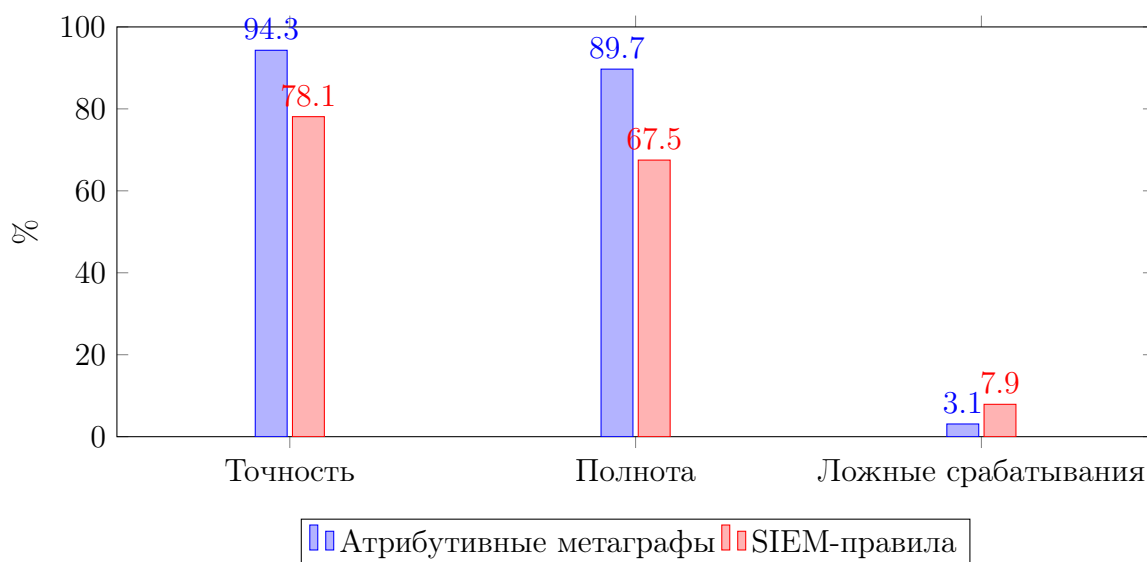


Рис. 6. Сравнение эффективности методов выявления атак

1. размер эталонных подграфов ограничен (≤ 10 вершин);
2. используется эвристическая фильтрация по атрибутам;
3. обработка распараллеливается по потокам.

Это позволяет удерживать время обработки в пределах **50 мс**, что приемлемо для систем реального времени.

Заключение

Предложенная методика выявления компьютерных атак на основе атрибутивных метаграфов обеспечивает высокую эффективность за счёт глубокого семантического моделирования логики атаки. Подход позволяет обнаруживать сложные, малозаметные сценарии, которые остаются незамеченными традиционными средствами. Методика соответствует современным требованиям к системам защиты информации и может быть успешно интегрирована в инфраструктуру безопасности государственных и коммерческих организаций.

Список литературы

1. Latypov I.T., Ereemeev M.A. Multilevel Model of Computer Attack Based on Attributive Metagraphs. *Aut. Control Comp. Sci.* **54**, 944–948 (2020). <https://doi.org/10.3103/S0146411620080192>
2. Методика оценки угроз безопасности информации, Москва: ФСТЭК, 2021.
3. Novokhrestov A.K., Konev A.A. Assessment of the security quality of computer networks. *Din. Sist. Mekh. Mash.*, 2014, no. 4, pp. 85–87.
4. MITRE ATT&CK Framework. <https://attack.mitre.org/>
5. ГОСТ Р 56939–2024. Разработка безопасного программного обеспечения. Общие требования.

6. Mallon S. Strategic Cybersecurity Leader & Executive Consultant, at Black Hat 2016: Extended Cyber Kill Chain. <https://www.blackhat.com/docs/us-16/materials/us-16-Malone-Using-An-Expanded-Cyber-Kill-Chain-Model-To-Increase-Attack-Resilience.pdf>
7. Astanin S.V., Dragnysh N.V., Zhukovskaya N.K., Nested metagraphs as models of complex objects. <http://www.ivdon.ru/en/magazine/archive/n4p2y2012/1434>

УДК: 004.056.5

ББК: 32.973.26-018.2